GAP ANALYSIS

📊 תכנית vs. מחקר — ניתוח פערים

כמה מה שתכננו מכסה את מה שהמחקר גילה? יתרונות, חסרונות, והמלצות שיפור.

🎯 סיכום ציונים

כמה מה שתיכננו מכסה את הדרישות שעלו מהמחקר

82%
כיסוי כולל
מה שתיכננו vs. מה שהמחקר גילה

7/10
OWASP LLM
סיכונים מכוסים מ-Top 10

✅
Anthropic מאשרים
הארכיטקטורה שלנו = Reference Implementation

4
פערים שנמצאו
דברים שלא תיכננו ועלו מהמחקר

5
רעיונות שיפור
שיפורים שהמחקר העלה

🔍 תכנית vs. מחקר — פריט אחר פריט

ירוק = מכוסה מלא · צהוב = חלקי · אדום = חסר · סגול = שיפור חדש

• מכוסה מלא — תיכננו ועונה על המחקר

Hook Architecture — HTTP Collector
PreToolUse/PostToolUse שולחים events ל-Collector מקומי. זה בדיוק ה-Reference Implementation הרשמי של Anthropic. ארכיטקטורה מושלמת.

בתכנית
Milestone 1 — hook.js + Collector port 3010

מכוסה מלא ✓

Anomaly Rules Engine

בתכנית

מכוסה מלא ✓

Signature + Context + Behavioral + Whitelist. מכסה curl|sh, rm -rf, base64, ngrok, פעילות חריגה. המחקר אישר שזה הכיוון הנכון.

Milestone 2 — rules.js, 4 סוגי חוקים

Secrets + DLP Scanner

סיסמאות, JWT, API keys (AWS/GitHub/OpenAI), כרטיסי אשראי, ת"ז ישראלית. Real-time Write Guard. מכוסה OWASP LLM06.

בתכנית

Milestone 6 — secrets-patterns.json + Write Guard

✓ מכוסה מלא

Skill Scanner — Supply Chain

Hash integrity + YARA + Semgrep + ClamAV + VirusTotal לפני כל התקנת Skill. מכסה OWASP LLM05 (Supply Chain Vulnerabilities).

בתכנית

Milestone 5 — 4 מנועים + Quarantine

✓ מכוסה מלא

Hardening Levels 0–3

OFF / SOFT / STRICT / LOCKDOWN. מכסה OWASP LLM08 (Excessive Agency). Telegram /approve + /deny לאישור ידני ב-Level 2.

בתכנית

Milestone 4 — Project Scope + 4 Levels

✓ מכוסה מלא

Claude עצירת — Block Mode

process.exit(1) עוצר את Claude לחלוטין. מכסה Excessive Agency ברמה הגבוהה ביותר. Exceptions management.

בתכנית

Milestone 10 — שלב ג'

✓ מכוסה מלא

Behavioral Monitoring — DoS Prevention

>20 WebFetch/דקה, >50 Read/5 דקות. מכסה OWASP LLM04 (Model Denial of Service) — זיהוי שימוש חריג במשאבים.

בתכנית

Milestone 2.4 — Behavioral Rules

✓ מכוסה מלא

Immutable Audit Log

Hash chain לוג — כל entry חתום, לא ניתן לשנות רטרואקטיבית. Audit trail מלא לCompliance וForensics.

בתכנית

Milestone 7.5

✓ מכוסה מלא

SIEM Integration

Syslog RFC 5424, Microsoft Sentinel (KQL), Splunk (SPL). ניתוח גלובלי ב-Splunk/Sentinel לאחר המחקר.

בתכנית

Milestone 11 — שלב ד'

✓ מכוסה מלא

• כיסוי חלקי — תיכננו, אבל המחקר גילה שצריך יותר

Prompt Injection Detection

בתכנית

⚠ חלקי

תיכננו Context Rules שמזהים patterns חשודים, אבל המחקר (OWASP LLM01) מגדיר Prompt Injection כסיכון נפרד שדורש זיהוי ספציפי בתוכן שClaude מקבל — לא רק בפקודות.

Milestone 2.2 — Context Rules (חלקי)

Insecure Output Handling

ה-Write Guard שלנו סורק secrets, אבל OWASP LLM02 מגדיר גם בדיקה שהקוד שנכתב לא מכניס XSS/SQLi/RCE. Semgrep ב-PostToolUse יכסה את זה — אך לא תיכננו את זה במפורש.

בתכנית

Milestone 6.4 — Write Guard (חלקי)

חלקי ⚠️

MCP Server Monitoring

תיכננו Hook כללי לכל tool, אבל Anthropic מדגישים MCP כסיכון נפרד. המחקר הראה שצריך matcher ספציפי לכל MCP write operations — `mcp__*__write*`.

בתכנית

Hook כללי — לא ספציפי ל-MCP

חלקי ⚠️

• חסר לחלוטין — לא תיכננו, עלה מהמחקר

WebDAV Windows Block

Anthropic מזהירים במפורש: paths שמתחילים ב- `\\*` ב-Windows יכולים לעקוף את Permission System דרך WebDAV. לא תיכננו חוק ספציפי לזה.

בתכנית

לא קיים כלל

חסר ✕

ConfigChange Hook

Anthropic מספקים hook `ConfigChange` — מופעל כשמישהו משנה את settings.json. לא ידענו על זה. חשוב לזהות ניסיון לכבות hooks או לשנות הגדרות אבטחה.

בתכנית

לא קיים כלל

חסר ✕

OpenTelemetry Export

Anthropic מספקים OTel מובנה. לא תיכננו לשלב OTel — כך EHZ-SEC-AI לא מדבר עם Prometheus/Grafana/Datadog קיימים בארגון. זה פער לסביבת Enterprise (שלב ב').

בתכנית

לא קיים (רלוונטי לשלב ב')

חסר ✕

Training Data / Model Theft Protection

OWASP LLM03 ו-LLM10 — Data Poisoning ו-Model Theft. אלה סיכונים שהמחקר הזכיר. לא ניתן להתגונן מהצד שלנו — זה ברמת Anthropic בלבד. חשוב לתעד את הגבול.

בתכנית

לא קיים — מחוץ לסקופ

מחוץ לסקופ

🔟 OWASP LLM Top 10 — כיסוי מפורט

כמה מכל סיכון EHZ-SEC-AI מכסה

סיכון	שם	כיסוי	איפה בתכנית	הערה
LLM01	Prompt Injection	60%	Milestone 2.2 — Context Rules	צריך שיפור — ראה הצעות
LLM02	Insecure Output	55%	Milestone 6.4 — Write Guard	Semgrep on Write יכסה יותר
LLM03	Data Poisoning	0%	—	מחוץ לסקופ — צד Anthropic
LLM04	Model DoS	85%	Milestone 2.4 — Behavioral Rules	Rate limiting חזק
LLM05	Supply Chain	90%	Milestone 5 — Skill Scanner	4 מנועים + Hash + Quarantine
LLM06	Sensitive Data	95%	Milestone 6 — Secrets + DLP	הכי חזק — כולל PII ישראלי
LLM07	Insecure Plugin	70%	Milestone 5 — MCP Hook (חלקי)	צריך matcher ספציפי
LLM08	Excessive Agency	100%	Milestones 4+10 — Hardening + Block	הכי חזק בשוק
LLM09	Overreliance	40%	Milestone 7.2 — Session Recording	בעיקר אחריות משתמש
LLM10	Model Theft	0%	—	מחוץ לסקופ — צד Anthropic

⚖️ יתרונות וחסרונות — תמונה מלאה

מה EHZ-SEC-AI עושה טוב, ומה הגבולות שלו

✅ יתרונות ברורים

⚠️ חסרונות ומגבלות

🎯 **ייחודי בשוק** — אין מוצר שמנטר Claude Code ספציפית דרך Hooks עם Dashboard + Telegram. Lasso ו-Spectral הם כלליים ויקרים.

✅ **Anthropic מאשרים** — הארכיטקטורה שלנו (HTTP Hook → Collector) היא Reference Implementation רשמי שלהם. בונים על היסודות הנכונים.

🆓 **חינמי לחלוטין** — YARA, ClamAV, Semgrep, Google Safe Browsing, VirusTotal (free tier). Lasso עולה עשרות אלפי דולר לשנה.

🇮🇱 **PII ישראלי ייחודי** — סריקת ת"ז, כרטיסי אשראי, מספרי טלפון ישראליים. אין מוצר אחר שעושה את זה.

📱 **Telegram + System Tray** — שילוב שלא קיים בשום מוצר. התראה לנייד + אייקון + Dashboard = כיסוי מלא.

🔒 **100% על Hardening** — **Excessive Agency** Levels + Block Mode = הכי חזק בשוק לשליטה על אוטונומיית Claude.

🏠 **מקומי לחלוטין** — הנתונים לא יוצאים לענן. כל הניתוח מקומי. פרטיות מלאה.

🔴 **WebDAV לא מכוסה** — Anthropic מזהירים על סיכון ספציפי ב-Windows שלא תיכננו. *דורש תיקון לפני שלב א'.*

🟡 **Prompt Injection — חלקי** — זיהוי בפקודות בלבד. לא בתוכן שClaude מקבל מ-WebFetch/קבצים. OWASP LLM01 הכי נפוץ.

🟡 **ConfigChange Hook חסר** — לא ידענו על ה-Hook הזה. מישהו יכול לשנות את settings.json ולכבות את ה-Hooks שלנו — בלי שנדע.

🟡 **MCP Monitoring כללי מדי** — Hook כללי לכל tool. לא matcher ספציפי ל-MCP write operations. עלול להחמיץ פעולות MCP מסוכנות.

⚪ **אין OTel Integration** — ארגונים עם Prometheus/Grafana לא יכולים לשלב EHZ-SEC-AI בתשתית הקיימת. פגיעה באימוץ ב-Enterprise.

⚪ **OWASP LLM03 + LLM10 = 0%** — Data Poisoning ו-Model Theft לא ניתן לטפל בהם מצד הלקוח. מגבלה מובנית שצריך לתעד בבירור.

⚪ **Node.js תלות** — מחייב Node.js על כל מחשב. MSI Installer מטפל בזה, אבל מוסיף מורכבות לפריסה.

🚀 המלצות שיפור — מה כדאי להוסיף

5 שיפורים ממוקדים שיעלו את הכיסוי מ-82% ל-95%+

🔴 עדיפות קריטית

הוסף חוק WebDAV ל Milestone 2

Anthropic מזהירים: paths שמתחילים ב- `\\` ב-Windows יכולים לעקוף Permission System. צריך להוסיף ל-Signature Rules:

```
if (path.startsWith('\\\\')) →
CRITICAL: WebDAV bypass attempt
```

🔴 עדיפות קריטית

הוסף ConfigChange Hook

כרגע אפשר לכבות את EHZ-SEC-AI על ידי עריכת settings.json ללא שנדע. ה-ConfigChange hook של Anthropic מתריע על זה:

```
ConfigChange" → hook → Telegram alert"
settings.json ⚠️ " שונה!"
```

זה שיפור פשוט של שורה אחת — לא דורש Milestone נפרד.

+ Milestone 2.1 — Signature Rules

בלי זה — האבטחה שלנו ניתנת לעקיפה.

+ Milestone 1.5 — ConfigChange Watcher

עדיפות גבוהה

שפר Prompt Injection Detection

כרגע Context Rules בודקים רק פקודות. OWASP LLM01 דורש גם בדיקת תוכן שClaude מקבל — מ-WebFetch, קריאת קבצים.

הוסף PostToolUse scanner שבודק אם תוצאת WebFetch/Read מכילה: `"ignore previous instructions"`, `"you are now"`, `"jailbreak"`

+ Milestone 2.5 — Prompt Injection Scanner

עדיפות גבוהה

MCP-Specific Hook Matchers

Anthropic מדגישים MCP כווקטור סיכון נפרד. הוסף matchers ספציפיים:

- `mcp__*__write*` → HIGH alert
- `mcp__*__delete*` → CRITICAL
- `mcp__*__exec*` → CRITICAL

כך ניתן לנטר MCP servers בנפרד מ-tools רגילים.

+ Milestone 2 או 5 — MCP Rules

שיפור מועיל

OpenTelemetry Output — לשלב ב'

ארגונים עם Prometheus/Grafana/Datadog לא יכולים לשלב EHZ-SEC-AI ללא OTel.

הוסף ל-Collector export של events בפורמט OTel סטנדרטי. כך EHZ-SEC-AI "מדבר" עם תשתית ניטור קיימת ולא מחליף אותה.

+ Milestone 9 — Domain/Enterprise

המסקנה הסופית

התכנית שלנו **טובה מאוד** — 82% כיסוי ממחקר עצמאי, ארכיטקטורה שAnthropic עצמם מאשרים, ויכולות שלא קיימות בשום מוצר מסחרי. עם **2 תיקונים קריטיים** (WebDAV + ConfigChange) ו-**2 שיפורים גבוהים** (Prompt Injection + MCP) נגיע ל-95%+ כיסוי — ונהיה **עדיפים על Lasso ו-Spectral** לסביבת Claude Code.

- ✅ ארכיטקטורה נכונה
- ✅ חינמי לגמרי
- ✅ ייחודי בשוק
- ⚠️ WebDAV — תקן לפני Milestone 1
- ⚠️ ConfigChange — הוסף ל-Milestone 1
- 💡 3+ שיפורים לאחר מכן